

TECHTALKS EDINBURGH #7

Inside Threat Intelligence.

*Tracking global cyber,
geopolitical & emerging threat actors.*

Cameron Cottam // Security Operations Analyst

Whoami



Cameron Cottam

Security Operations Analyst

Threat intelligence

Detection engineering

Proactive defence



~3 years in the field

Managed security service providers & internal financial services team



What I do

Track threat actors, build detections, hunt for things that aren't alerting.

Closer to the frontline than you think

Oleksandr just showed you how agents use tools and make decisions. Attackers are building those too — and your laptop is their target.



Your packages

npm, PyPI, GitHub Actions —
attacker-owned dependencies quietly
shipped



Your laptop

Dev machines hold tokens, SSH keys,
cloud sessions — a higher-value target
than your CFO's



Your cloud

CI/CD secrets, IAM roles, OAuth scopes
— one stolen token is a one-way ticket

What threat intelligence is

*Evidence-based knowledge about the people, tools, and motives behind cyber attacks — **turned into informed decisions you can defend with.***



- Structured, sourced, verifiable
- About actors, not just indicators
- Fuel for decisions: detect, patch, hunt



- Doomscrolling Twitter or Telegram
- A magic feed that predicts breaches
- A substitute for security fundamentals

Strategic, Operational, Tactical



STRATEGIC

The board room

Geopolitics and long-term actor goals. Shapes where the organisation invests.

OPERATIONAL

The war room

Who's attacking, why, and what they're capable of. Emerging campaigns.

TACTICAL

The SOC floor

The sharp end — IOCs, malware families, attack patterns.

Who we're tracking



Malicious insiders

Trusted access, damaging intent



Organised crime

Ransomware for profit



State-sponsored

Nation-backed operators



Hacktivists

Politically motivated



Career criminals

Professional, financially driven



Terrorist groups

Ideological disruption



Script kiddies

Opportunists with borrowed tools



APT groups

Stealthy, long-term, well-resourced

Meet the APTs

Sophisticated. Well-resourced. Often state-sponsored. They don't smash and grab — they live in your network for months.

Lazarus Group

DPRK-LINKED

Financial heists, crypto exchange raids, destructive malware. Funds a regime.

Scattered Spider

ENGLISH-SPEAKING, YOUNG

Social-engineering specialists. Help desks are their front door. We'll come back to them.

The 2016 classic: Bangladesh Bank

Before they came for crypto exchanges, they came for a central bank — and nearly got a billion dollars.

HOW IT UNFOLDED

Oct 2014

Reconnaissance begins

DPRK hackers research specific Bangladesh Bank employees

Jan 2015

Spear-phishing delivers malware

One employee opens a fake job CV. Keyloggers installed.

16 months

Living inside the network

Mapping SWIFT workflows, harvesting credentials, waiting.

Feb 2016

35 transfer requests fired

\$951M attempted. \$81M got out. Timed for the weekend.

16 months.

dwelt time inside the network

\$81M

stolen. Most never recovered.

\$951M

attempted. A typo stopped the rest.

4 servers

connected to SWIFT. None monitored.

This is what "Persistent" looks like in APT. They don't rush — they earn their access.

The 2025 evolution: crypto heists

What they're doing now

- Fake job interview/recruitment campaigns
- Malicious NPM and PyPi packages
- Collaboration with Russian nationals
- £1.5 Billion stolen from Bybit

How threat intel responded

- Peer sharing through sector channels in near real-time
- Tactical intel traded: IOCs, infrastructure and dependency used
- Operational intel: actor motive, affiliate structure, likely next targets
- Now raises the question of how much trust you have with developers/engineers installing open-source packages and with AI agents

#10 • EVIDENCE • DPRK-LINKED APTs

	 GOLDEN CHOLLIMA	 LABYRINTH CHOLLIMA	 PRESSURE CHOLLIMA
OBJECTIVE	Cryptocurrency theft	Intelligence collection	Cryptocurrency theft
 TARGETS	• Small fintech firms • U.S., Canada, South Korea, India, Western Europe	• Defense • Maritime • Military • Government • Logistics • Nuclear • U.S., Europe, South Korea	• Centralized exchanges • Technology • U.S., Europe, India, East Asia
 KEY TTPs	• Malicious applications disguised as cryptocurrency traders • Cloud-conscious intrusions • Chromium zero-day vulnerabilities • HR-themed social engineering • Supply chain compromise • Trojanized Python Projects	• Fake PDF readers and TightVNC to deploy malware • HR-themed social engineering • Trojanized Node.js and Python projects • Rootkit deployment • Zero-day vulnerabilities	• Malicious applications disguised as cryptocurrency traders • Supply chain compromise • Trojanized Node.js and Python projects
 KEY MALWARE	• Jeus • HTTPHelper • SnakeBaker • NodalBaker	• Hoplight • HTTPHoplight • OpenSSLDownloader • UnderGroundRAT • NedDnLoader • HiberRAT • FudModule	• MataNet • SparkDownloader • TwoPence Electric • MagikCookie • StatusSymbol • Scuzzyfuss • IndexSymbol • GhostShip • AlertConf
COMMUNITY IDENTIFIERS	Jeus, AppleJeus, Citrine Sleet, Gleaming Pisces, UNC1720, UNC4736	Diamond Sleet, Moonstone Sleet, Operation Dream Job, Operation Interception, Selective Pisces, TA404	TraderTraitor, Mata, Jade Sleet, Slow Pisces, UNC4899

Scattered Spider & UK retail

What happened

- Major UK retailers hit in a coordinated wave
- Social engineering via help desks, not zero-days
- Operational disruption visible to the public — gaps on shelves, online orders paused
- Tens of millions in lost revenue per affected retailer

How threat intel responded

- Peer sharing through sector channels in near real-time
- Tactical intel traded: IOCs, phishing lures, help-desk TTPs
- Operational intel: actor motive, affiliate structure, likely next targets
- Every untouched retailer asked the same question: "Are we already in scope?"

British Scattered Spider hacker pleads guilty to crypto theft charges

By [Sergiu Gatlan](#)

April 20, 2026 09:33 AM 0



A British man, believed to be the leader of the Scattered Spider cybercrime collective, has pleaded guilty in the United States to charges of wire fraud and aggravated identity theft.

In November 2024, U.S. prosecutors [accused](#) 24-year-old Tyler Robert Buchanan and four other suspects of stealing at least \$8 million in cryptocurrency after hacking at least a dozen companies through text-message phishing attacks between September 2021 and April 2023.

02

When the supply chain *becomes the weapon.*

Open-source packages, maintainer accounts, OAuth tokens — the ingredients of every modern app are the attacker's entry point.

When the supply chain is the attack



node_modules
is a threat surface.

Every install is a trust decision. Most are made by scripts, not humans.

1 Compromise

Phishing, stolen token, hijacked account



2 Publish

Malicious version ships, auto-installs everywhere



3 Blast radius

Secrets exfiltrated, dev machines backdoored



4 Discovery

Not your EDR. A security researcher on X.

Controlled upgrades, lockfiles, dependency review — these are countermeasure.

The year the supply chain burned

Seven incidents. Billions of weekly downloads exposed. Most of them installed in your CI pipelines before anyone noticed.



Geopolitics is a threat vector



IRAN / USA / ISRAEL

Alliances of convenience

Iranian hackers aligning with Russian groups in solidarity against US and Israeli targets. Reconnaissance against Middle East cloud infrastructure — who uses what, and where does it live.



RUSSIA / UKRAINE

NoName057 on Telegram

Russian hackers operate public Telegram channels, claim responsibility for DDoS attacks against Western government, critical infrastructure, and financial institutions. Narrative is the weapon; Telegram is the megaphone.

The toolkit: TIPs



What a TIP does

- Consolidates strategic, operational, and tactical feeds
- Curated IOCs mapped to actors, campaigns, and malware families
- Monitors dark web forums, infostealer logs, Telegram channels
- Enriches alerts with actor context, not just a reputation score

Platforms

Recorded Future

Commercial — broad coverage, heavy automation

ThreatConnect

Commercial — strong on workflow and analyst collab

OpenCTI / MISP

Open source — community-driven, free to run

Browse / <https://urheant.com/>

Revert to Legacy View

Explore in Graph



<https://urheant.com/>

URL Indicator

Source: Bayse.io



Follow Item

Notification Priority



Active

Status set by



Overview

Associations 2320

Activity

Enrichment

Overview

Collapse All

Expand All

Details



Private

ThreatAssess & CAL



ThreatAssess Impact Factors

- Recent False Positive Reported
- Impacted by Recent Observations

Security Labels

No security labels

Confidence Rating

100 - Confirmed

Threat Rating

High

Date Added

2024-03-12 07:45:16 GMT

Last Modified

2024-03-13 07:43:33 GMT

Description

None specified

TIPs aren't the holy grail

A TIP builds the foundation. *But there is so much more.*



Quarterly threat reports

CrowdStrike, Mandiant, Microsoft and others publish deep analysis on emerging actors and campaigns. Free, detailed, and often the primary source a TIP is citing.



OSINT, blogs, researchers

Independent researchers and vendor blogs often break new TTPs weeks before they land in commercial feeds. X, Mastodon, and direct vendor RSS are part of the job.



ISACs & sector groups

FS-ISAC (financial services) and peers let companies in the same sector share early warnings under trust agreements. Often more current than any paid feed.



The infostealer economy

Infostealers are the plumbing of modern breaches. Cheap, fast, and almost invisible.



How the log economy works

1

Infection

Cracked software, malvertising, phishing. Target is the browser, not the OS.

2

Harvest

Passwords, session cookies, MFA tokens, SSH keys, cloud creds — all of it.

3

Sell

Logs listed on Russian Market, Telegram channels, underground forums.

4

Exploit

Initial Access Brokers package creds, sell to ransomware affiliates.

2 days

average from a credential appearing in a stealer log to a ransomware incident.

Source: Verizon DBIR 2025

TOP ACTIVE FAMILIES (Q1 2026)

Vidar 2.0

#1 Post-Lumma disruption

ACRStealer

Private ops, restricted access

StealC v2

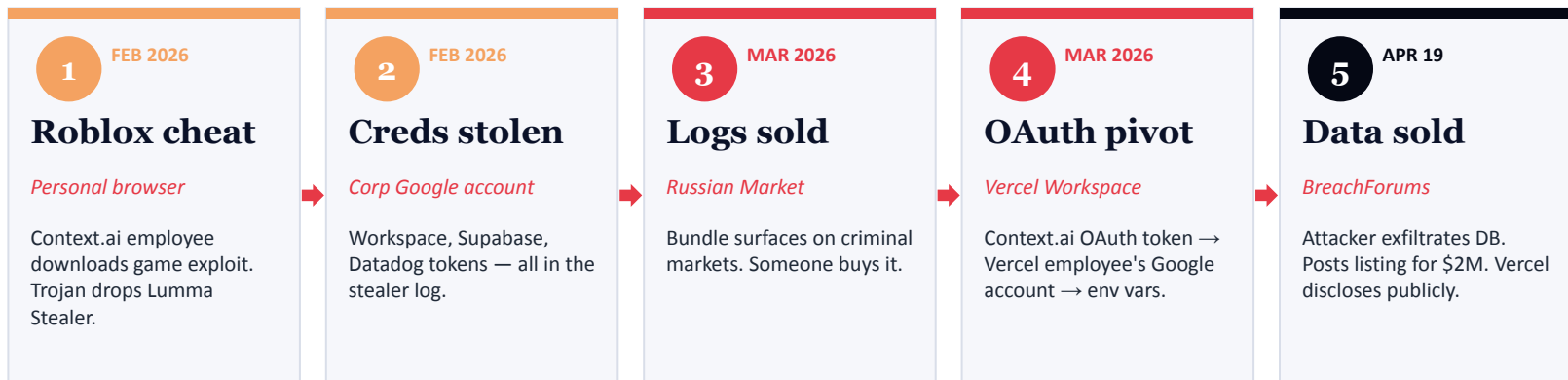
Rebranded after takedown

LummaC2

Disrupted May '25, rebuilt

Four days ago: the Vercel breach

A Roblox cheat download two months ago ended with a developer platform's data for sale on BreachForums for \$2M.



THE CHAIN IN ONE LINE

Personal browsing habits → corporate creds → OAuth → your customers' data.

WHY IT MATTERS

You don't need a nation-state attacker. The supply chain for this kit is retail.

Where the ugly stuff lives



RANSOMWARE LEAK SITES

Public shame as leverage

Tor-hosted (sometimes clearweb) portals where RaaS groups post victim data when ransoms aren't paid.

Qilin

1,213 victims in 2025

Akira

1,044 victims

Clop

MOVEit, CLOP clearweb dumps

RansomHub, DragonForce, Rhysida

Active newer names



UNDERGROUND MARKETS

Stolen data for sale

Where infostealer logs, corporate accesses, and breach dumps get traded. Often the first signal your org is compromised.

BreachForums

Seized '24, reborn. Vercel data listed for \$2M here

XSS / Exploit.in

Russian-language, long-standing

Russian Market

Stealer log marketplace

Telegram IAB channels

Initial access auctions



WHAT WE DO WITH IT

Monitor, not participate

Automated scraping + human analyst review.

Company mentions

Domain, employees, tech stack

Leaked credentials

Match against workforce emails

Early warning

Your data appears before you know it's gone

Strategic signal

Which sectors are being hit next

Assume you're already breached

Threat hunting is the next stage within Threat Intel.



Where to begin

- Alerts catch yesterday's attacker. Hunts catch today's.
- If you're only reacting to alerts, you're only seeing what got past you loudly
- Working assumption: a breach is already in motion
- Intel supplies the hypothesis to test



What we hunt for

- APTs living quietly for weeks or months
- Insider misuse that never trips a rule
- Fileless malware — nothing on disk to scan
- Legitimate tools used for illegitimate ends

AI: the double-edged sword



ATTACKERS

- AI-generated phishing at scale, in any language
- Malware written and mutated by LLMs
- Automated recon against your public footprint
- Deepfake voice and video for social engineering



DEFENDERS

- Agentic SOC — AI triaging alerts, not just flagging them
- Automated isolation of compromised systems
- Dynamic blocking of verified malicious infrastructure
- LLM-assisted hunt queries and report synthesis

The unglamorous truth

1

Legitimate artefacts get flagged

AWS metadata endpoints, Microsoft telemetry, CDN IPs — cloud infrastructure triggers "suspicious" signatures constantly.

2

Feeds disagree

One provider says malicious, another says benign. Both are often partly right. Context decides.

3

Indicators rot fast

An IP is malicious on Tuesday and hosts a bakery website on Friday. Acting on stale intel creates its own incidents.

Three things to look up this week.

- 01** Read one threat report
 - 02** Spin up MISP/OpenCTI (it's free)
 - 03** Audit one dependency tree
-

CrowdStrike Threat Report



Any questions?

